

INCIDENT RESPONSE PLAYBOOK

Phishing / Credential Theft

Aligned to NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
Includes: SOC Standard Operating Procedure + Sample Case Study

ORGANIZATION

Meridian Defense Systems, LLC

Security Operations Center | Incident Response Team

DOCUMENT ID
MDS-SOC-IRP-001
VERSION
1.0
REVIEW CYCLE
Annual

CLASSIFICATION
SIMULATED / TRAINING
EFFECTIVE DATE
2024-11-01
AUTHOR
D. Taylor Jr. — SOC Analyst

Table of Contents

PART I — SOC STANDARD OPERATING PROCEDURE

1. Purpose & Scope	3
2. Roles & Responsibilities	3
3. Detection & Initial Triage	4
4. Containment	4
5. Eradication	5
6. Recovery	5
7. Post-Incident Activity	5
8. Escalation Thresholds	6

PART II — SAMPLE CASE STUDY

Incident Overview	7
Incident Timeline	8
Indicators of Compromise (IOCs)	9
Technical Analysis	9
Response Actions Taken	10
Lessons Learned & Recommendations	11

Document	Phishing / Credential Theft — Incident Response Playbook
Reference	NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
Applies to	All Meridian Defense Systems endpoints, email systems, and user accounts
Severity	P1 (Critical) if executive or privileged account affected; P2 (High) otherwise

1. Purpose & Scope

This playbook defines the standard operating procedure for detecting, containing, eradicating, and recovering from phishing incidents and associated credential theft at Meridian Defense Systems (MDS). It applies to all SOC analysts, system administrators, and IT support personnel.

Phishing represents one of the most prevalent initial access vectors for threat actors targeting defense industrial base (DIB) organizations. Given MDS's work with controlled unclassified information (CUI) and sensitive government contracts, a successful credential theft event may trigger CMMC and DFARS incident reporting obligations within **72 hours**.

2. Roles & Responsibilities

SOC Analyst (Tier 1)	Initial triage, alert validation, escalation per this playbook
SOC Analyst (Tier 2)	Deep-dive investigation, forensic artifact collection, IOC documentation
Incident Commander (IC)	Declared when P1 severity; coordinates cross-functional response
IT / Sysadmin	Account lockouts, password resets, endpoint isolation, log pulls
Legal / Compliance	Advises on DFARS 252.204-7012 and CMMC breach notification requirements
End User	Reports suspicious emails; cooperates with investigation; does not forward

3. Detection & Initial Triage

3.1 Detection Triggers

- SIEM alert: Multiple failed authentication attempts following email delivery event
- End-user report via helpdesk ticket or email to phishing@mds-defense.com
- EDR alert: Credential access behavior (LSASS memory read, Mimikatz signature)
- Email gateway flag: External sender impersonating internal domain (lookalike domain)
- Wazuh rule 100003 fires: New local admin account created within 10 min of phish delivery

- O365 alert: Impossible travel or atypical country login on user account

3.2 Triage Checklist (Tier 1 — target: 15 minutes)

1	Validate alert	Confirm alert is not a false positive. Check sender reputation, SPF/DKIM/DMARC results, and email headers.
2	Identify scope	Determine how many users received the email. Pull distribution from email gateway logs.
3	Check for clicks	Query proxy/DNS logs: did any user click the link or download the attachment?
4	Check for creds	Query SIEM/IdP logs: any new authentications or password changes since delivery?
5	Assess severity	Apply severity matrix (P1 if exec/admin creds involved; P2 otherwise). Page IC if P1.
6	Notify	Open incident ticket. Notify Tier 2 and IC (if P1). Do not notify end users yet.

4. Containment

4.1 Short-Term Containment (0–2 hours)

- **Lock compromised accounts immediately** — disable in Active Directory; revoke all active sessions in IdP (Azure AD / Okta).
- Quarantine the phishing email from all mailboxes using email admin console (purge, do not soft-delete).
- Block sender domain and IP at email gateway and perimeter firewall.
- If attachment executed: isolate affected endpoint from network (EDR network isolation or physical disconnect).
- Preserve: do NOT wipe the endpoint — collect memory dump and disk image first.

4.2 Long-Term Containment (2–24 hours)

- Deploy updated YARA/Suricata rules for identified malware hash or C2 domain.
- Enable enhanced logging on affected systems: PowerShell ScriptBlock, WMI, scheduled tasks.
- Force MFA re-enrollment for all users in the same department as the victim.
- Notify downstream system owners if compromised account had cross-system access.

5. Eradication

- Remove malicious email from all mailboxes and email archives.
- Delete any malicious files, scheduled tasks, registry keys, or persistence mechanisms identified on endpoint.
- Rotate all credentials for the compromised account and any shared service accounts it had access to.

- Scan all endpoints in the same network segment with updated AV signatures and EDR hunt query.
- Review and revoke any OAuth grants or API tokens issued under the compromised identity.
- Validate removal: re-run EDR hunt query and confirm zero matches before proceeding.

6. Recovery

- Restore endpoint from known-good image or reimage from scratch — do not attempt in-place cleanup for P1.
- Re-enable user account only after identity is verified (video call with manager), credential reset, and MFA re-enrollment.
- Monitor re-enabled account with enhanced SIEM alerting for 72 hours post-recovery.
- Gradually restore network access; validate no re-infection within 24 hours before full clearance.
- Confirm all IOCs have been blocked at email gateway, DNS sinkhole, firewall, and EDR.

7. Post-Incident Activity

7.1 Lessons Learned (due within 5 business days)

- Schedule post-incident review with SOC, IT, and Incident Commander.
- Document: timeline, root cause, detection gap (how long before detection?), actions taken, and impact.
- Identify what detective or preventive controls would have stopped or shortened the incident.
- Update this playbook with any procedural gaps identified.

7.2 Regulatory Reporting

If CUI, ITAR-controlled data, or government contract data was accessed or exfiltrated, MDS is required to report the incident to the DoD CIO via the DIBNet portal within **72 hours** of discovery under **DFARS 252.204-7012**. Legal and Compliance must be notified immediately upon any P1 declaration to begin the reporting clock.

8. Escalation Thresholds

Condition	Severity	Action
Phishing email received, no clicks confirmed	P3 — Low	Monitor, block sender, close ticket if no activity in 24h
User clicked link; no credential entry or execution	P2 — Medium	Triage per §3.2, scan endpoint, reset password as precaution
Credential entry confirmed on phish page	P2 — High	Full playbook activation; lock account; Tier 2 investigation
Executive, admin, or service account compromised	P1 — Critical	Page IC; activate DFARS reporting clock; executive notification

Data exfiltration confirmed or suspected	P1 — Critical	Legal hold; forensic preservation; DIBNet notification within 72h
--	----------------------	---

PART II — SAMPLE CASE STUDY

Operation Credential Harvest

Incident Overview

Incident ID	INC-2024-0047
Date / Time	2024-10-14 08:23 EST (detected) — 09:41 EST (contained)
Severity	P2 — High (elevated to P1 review pending exfiltration assessment)
Classification	Phishing / Spear-Phishing — Credential Theft
Affected User	M. Chen — Contracts Analyst, Program Management Office
Systems Affected	CORP-WS-0114 (Windows 10 endpoint), MDS Microsoft 365 tenant
Analyst	D. Taylor Jr. — SOC Analyst, Tier 1 / Tier 2
Status	CLOSED — Contained, eradicated, recovered. PIR completed 2024-10-21.

Narrative Summary

On the morning of October 14, 2024, a spear-phishing email was delivered to M. Chen, a Contracts Analyst in the MDS Program Management Office with access to active government contract documentation. The email impersonated the MDS IT Help Desk and directed Chen to a convincing replica of the company's Microsoft 365 login portal, hosted on a lookalike domain. Chen entered her credentials, triggering an immediate session hijack. The threat actor authenticated to her M365 account from an IP in Eastern Europe within 47 seconds of credential submission.

The Wazuh SIEM generated an alert on the anomalous geographic login. The SOC analyst on shift validated the alert within 8 minutes, confirmed credential compromise, and initiated this playbook. The account was locked within 23 minutes of the initial phish delivery. No confirmed exfiltration was identified, though forensic review of email access logs revealed the threat actor browsed Chen's inbox for approximately 38 seconds before the session was terminated.

Incident Timeline

Time (EST)	Actor	Event
08:23:11	Threat Actor	Phishing email delivered to chen.m@mds-defense.com from support@mds-helpdesk[.]net (lookalike domain). Subject: 'ACTION REQUIRED: MFA Re-enrollment by EOD'.

08:31:44	M. Chen	User clicks embedded link. Browser navigates to <code>hxxps://mds-portal[.]net/login</code> — credential-harvesting page mimicking MDS M365 login portal.
08:32:09	M. Chen	User submits credentials on phishing page.
08:32:56	Threat Actor	Successful authentication to MDS M365 tenant from IP 185.220.101.47 (Bucharest, RO). Session established via stolen session token.
08:33:34	Threat Actor	Threat actor accesses Outlook inbox. Browses 3 email threads related to active IDIQ contract. No downloads observed in log.
08:34:12	Wazuh SIEM	Alert fires: Rule 100201 — Impossible Travel. Login from RO IP detected within 4 minutes of prior US-based session. Alert routed to SOC queue.
08:39:05	D. Taylor Jr.	SOC analyst receives alert. Begins triage. Confirms anomalous login. Pulls O365 audit logs.
08:44:30	D. Taylor Jr.	Credential compromise confirmed. Escalated to Tier 2. IT admin notified. Incident ticket INC-2024-0047 opened.
08:46:01	IT Admin	M. Chen's account disabled in Azure AD. All active sessions revoked via Entra ID portal.
08:46:48	Threat Actor	Session terminated — token invalidated. Threat actor loses access.
09:05:00	D. Taylor Jr.	Phishing email purged from all MDS mailboxes. Sender domain and IP blocked at email gateway and perimeter firewall.
09:18:00	D. Taylor Jr.	Endpoint CORP-WS-0114 isolated via EDR. Forensic image initiated.
09:41:00	D. Taylor Jr.	All IOCs confirmed blocked. Eradication complete. Incident contained.
10:15:00	IT Admin	M. Chen identity verified via manager video call. Password reset and MFA re-enrolled. Account restored with enhanced monitoring.

Indicators of Compromise (IOCs)

Type	Indicator	Notes
------	-----------	-------

Sender Domain	mds-helpdesk[.]net	Lookalike domain registered 2024-10-11. Not affiliated with MDS.
Phish URL	hxxps://mds-portal[.]net/login	Credential-harvesting page. Defanged for safety.
Actor IP	185.220.101.47	Tor exit node / bulletproof hosting. Bucharest, RO. Block at perimeter.
Email Subject	ACTION REQUIRED: MFA Re-enrollment by EOD	Social engineering lure. Urgency-based.
Email From	it-support@mds-helpdesk[.]net	Impersonates MDS IT Help Desk. SPF: FAIL. DMARC: none.
Wazuh Alert	Rule 100201 – Impossible Travel	Custom rule. Fired on geographic anomaly within 5 min window.

All external indicators have been defanged (hxxps, [.]) to prevent accidental navigation.

Technical Analysis

Email Header Analysis

- **SPF:** FAIL — mds-helpdesk[.]net has no authorized sending IPs matching the source.
- **DKIM:** NONE — No DKIM signature present on the message.
- **DMARC:** NONE — Domain has no published DMARC policy; no quarantine or reject enforcement.
- **Return-Path:** Mismatched — return-path pointed to a third-party bulk mail provider.
- **X-Originating-IP:** 185.220.101.47 — matches Tor exit node database.

Phishing Page Analysis

The credential-harvesting page at mds-portal[.]net was a near-pixel-perfect replica of the MDS Microsoft 365 sign-in portal. The page used a valid TLS certificate issued by Let's Encrypt, making the padlock visible to users. Credential submission triggered a POST to an actor-controlled endpoint, after which users were redirected to the legitimate MDS portal to avoid suspicion. The domain was registered via NameSilo using a privacy-protected registrant 3 days prior to the attack.

SIEM Detection — Wazuh Rule 100201

The following custom Wazuh rule detected the impossible travel anomaly that triggered the SOC response:

```
18127
^(10\.|172\.|(1[6-9]|2[0-9]|3[01])\.|192\.168\.)
3
alert_by_email
Impossible travel: 0365 login from non-RFC1918 IP within 5 min of domestic session
authentication_success,anomaly,credential_theft,
```

Rule 100201 is triggered when a successful authentication event (SID 18127, mapped from O365 sign-in logs) originates from a non-RFC1918 IP address within a 5-minute window of a prior domestic session. Severity level 12 routes the alert immediately to the SOC analyst queue with an email notification.

Response Actions Taken

Detection	Wazuh Rule 100201 fired on impossible travel anomaly. SOC analyst validated within 8 minutes.
Containment	Azure AD account disabled; all M365 sessions revoked; phishing domain blocked at gateway and firewall; endpoint isolated via EDR within 55 minutes of phish delivery.
Eradication	Phishing email purged from all mailboxes. Sender domain and IP blocked at perimeter. No persistence mechanisms identified on endpoint (forensic review complete).
Evidence	Full forensic image taken of CORP-WS-0114 prior to remediation. O365 UAL (Unified Audit Log) exported and retained per IR evidence retention policy (90 days).
Recovery	M. Chen identity re-verified via video call with manager. Credentials reset. MFA re-enrolled with hardware TOTP. Account re-enabled with 72-hour enhanced monitoring.
Reporting	No CUI exfiltration confirmed. DFARS 72-hour mandatory reporting threshold not met. Incident documented in GRC platform. Legal notified as precautionary measure.

Lessons Learned & Recommendations

What Worked Well

- Custom Wazuh impossible-travel rule (100201) detected the incident within 47 seconds of actor authentication — well within the detection SLA.
- SOC-to-IT communication was fast: account lockout occurred within 14 minutes of analyst alert acknowledgment.
- Endpoint forensic preservation was completed before any remediation, maintaining chain of custody.

Gaps Identified

- The phishing email was not caught by the email gateway — DMARC enforcement was not configured on the mds-helpdesk[.]net lookalike domain (MDS has no control over external domains, but aggressive DMARC on the internal domain would have flagged it).
- The user clicked the link despite the domain mismatch — phishing awareness training had not been conducted in 11 months.
- No pre-authentication anomaly detection was in place — the SIEM rule fired *after* successful login, not on the credential submission event itself.

Recommendations

R-01	HIGH	Deploy DMARC p=reject on mds-defense.com and enforce domain impersonation protection in M365 Defender for all lookalike domains.
R-02	HIGH	Implement phishing-resistant MFA (FIDO2 hardware keys or passkeys) for all users with access to CUI or government contract data.
R-03	MEDIUM	Schedule phishing simulation and awareness training quarterly. Track click rates by department. Flag departments exceeding 10% click rate for mandatory re-training.
R-04	MEDIUM	Integrate real-time threat intelligence feed into Wazuh. Auto-block known phishing domains at DNS layer before user can reach the page.
R-05	LOW	Evaluate browser isolation solution for high-risk user segments (PMO, finance, BD) to prevent credential entry on uncategorized domains.

This document was produced as part of a cybersecurity home lab portfolio project. Meridian Defense Systems is a fictional organization. All incidents, individuals, and data are simulated for training and demonstration purposes. No real classified, CUI, or sensitive government data is contained herein.